

Control Flow Integrity

UNIVERSITY OF TEXAS AT DALLAS
INSURE SPRING 2017
PROGRESS REPORT



Introduction

Problem

Problem

- ▶ Malware redirects flow of execution (control flow)
- ▶ Control flow integrity (CFI) prevents execution flow hijacking
- ▶ NSA created two CFI techniques in need of testing:
 - ▶ Landing Point Instructions
 - ▶ Shadow Stack



Definitions

- ▶ Landing Point Instructions (or landing pads) – instruction to verify landing at label associated with branching instructions
 - ▶ CLP, JLP, RLP



Landing Point Instructions

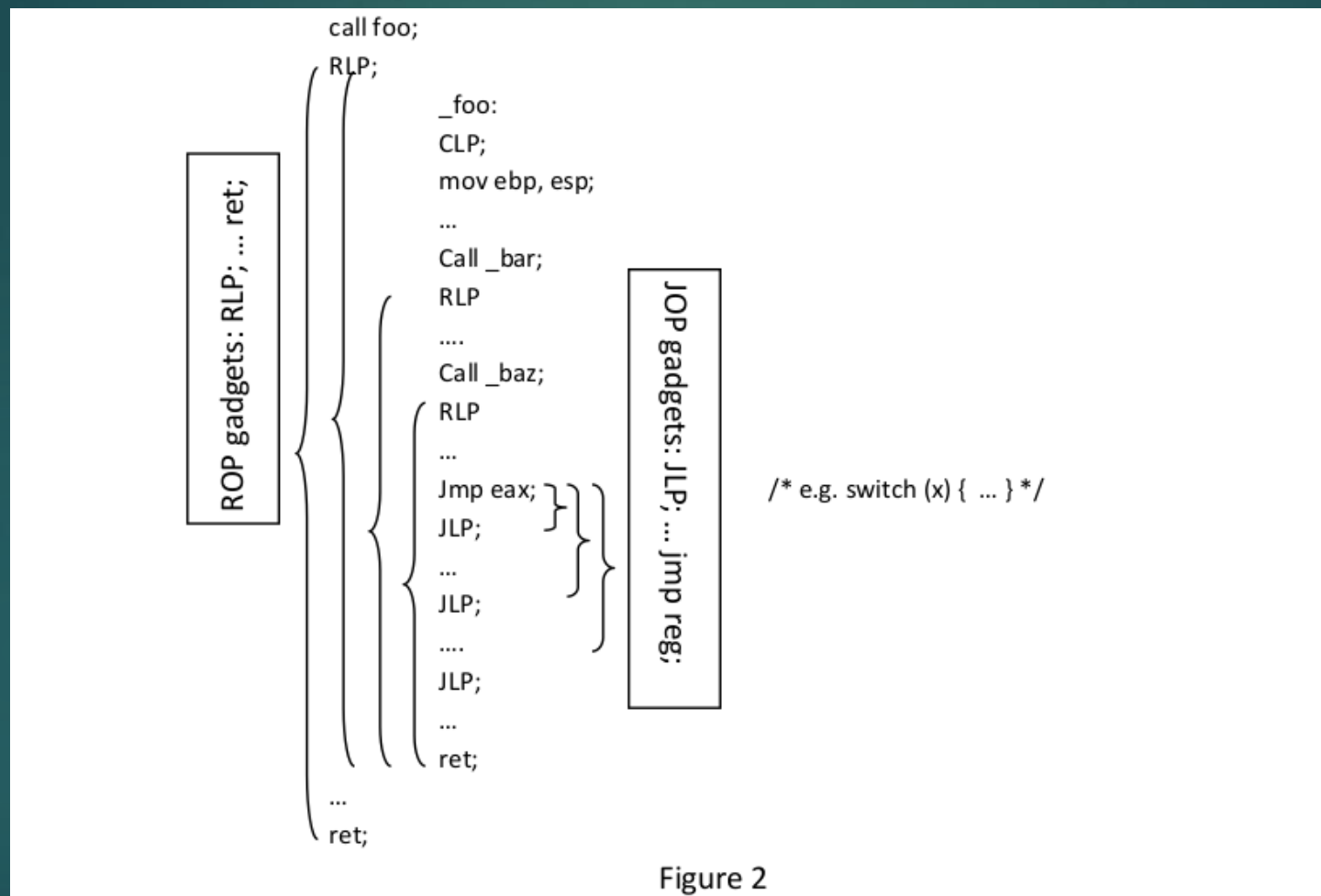


Figure 2

Source: NSA Information Assurance Directorate. *Hardware Control Flow Integrity for an IT Ecosystem*. April 2015.

Definitions contd.

- ▶ Landing Point Instructions – instruction to verify landing at label associated with branching instructions
 - ▶ CLP, JLP, RLP
- ▶ Shadow Stack – external, protected stack that stores copy of return addresses to be later checked for validity



Definitions contd.

- ▶ Landing Point Instructions – instruction to verify landing at label associated with branching instructions
 - ▶ CLP, JLP, RLP
- ▶ Shadow Stack – external, protected stack that stores copy of return addresses to be later checked for validity
- ▶ Gadget – assembly code used to alter control flow



Purpose

Purpose

- ▶ Project aims to test landing point instruction technique
- ▶ Chain gadgets to produce unexpected changes
 - ▶ Manipulate registers (specifically EAX/RAX)



Motivation & Impact

- ▶ Control flow integrity is vital to prevent the spread of malware
- ▶ NSA's CFI techniques are crucial to the future of malware mitigation
- ▶ These techniques cannot be implemented without thorough testing and evaluation
- ▶ Demonstrating effectiveness of these techniques could lead to future implementations of these techniques
- ▶ Finding weaknesses will provide researchers the opportunity to strengthen the techniques before they are implemented





Progress

Plan Overview

- ▶ Reduce the scope of the project
- ▶ Idea: Find a string of gadgets that bypasses the shadow stack and landing pads
- ▶ Sort through gadgets and find good ones to test.
- ▶ Chain together gadgets to attempt to break the CFI methods



Detailed Plan

Work Completed

- ▶ Create tool to split gadget files into testable components

Work in Progress

- ▶ Manually assess feasibility of gadgets

Work To Be Completed

- ▶ Intelligently combining gadgets to determine effects on registers and shadow stack



Results to Date

- ▶ Tool capable of splitting and categorizing individual gadgets from provided files
- ▶ Gadgets containing jump, call, and return statements are considered "hard"
 - ▶ Gadgets without these statements are "easy"
- ▶ Tool strips out all jump, call, and return statements



Issues

- ▶ Limiting scope



Issues

- ▶ Limiting scope
- ▶ Finding a needle in a haystack
- ▶ Thousands of gadgets to analyze and test within limited time constraints



Schedule

Left to Do:

- ▶ Apr 7: Analyze individual gadgets
- ▶ Apr 14: Test gadgets against provided Linux binary file
- ▶ Apr 21: Additional testing and final report draft
- ▶ May 5: Submit final report and presentation





Questions?